

VULNERABILITY ASSESSMENT REPORT
TARGET: DEMO.TESTFIRE.NET

PREPARED BY: TEMESEGEN MEKONNEN
DATE: APRIL 2026

OBJECTIVES

1. identify common security weaknesses
2. Classify risks in a business-friendly way
3. Explain issues clearly
4. Suggest practical remediation steps



SCOPE

1. Public-facing pages only
2. No exploitation performed

METHODOLOGY

1. Passive scanning
2. Header analysis
3. Configuration review

BASIC TOOLS USED TO PASSIVELY TEST

1. Nmap (Port scanning)
2. OWASP ZAP (Passive vulnerability detection)
3. Browser DevTools (Header and Cookie analysis)



SUMMARY OF FINDINGS

01

Medium-risk and low-risk vulnerabilities identified

02

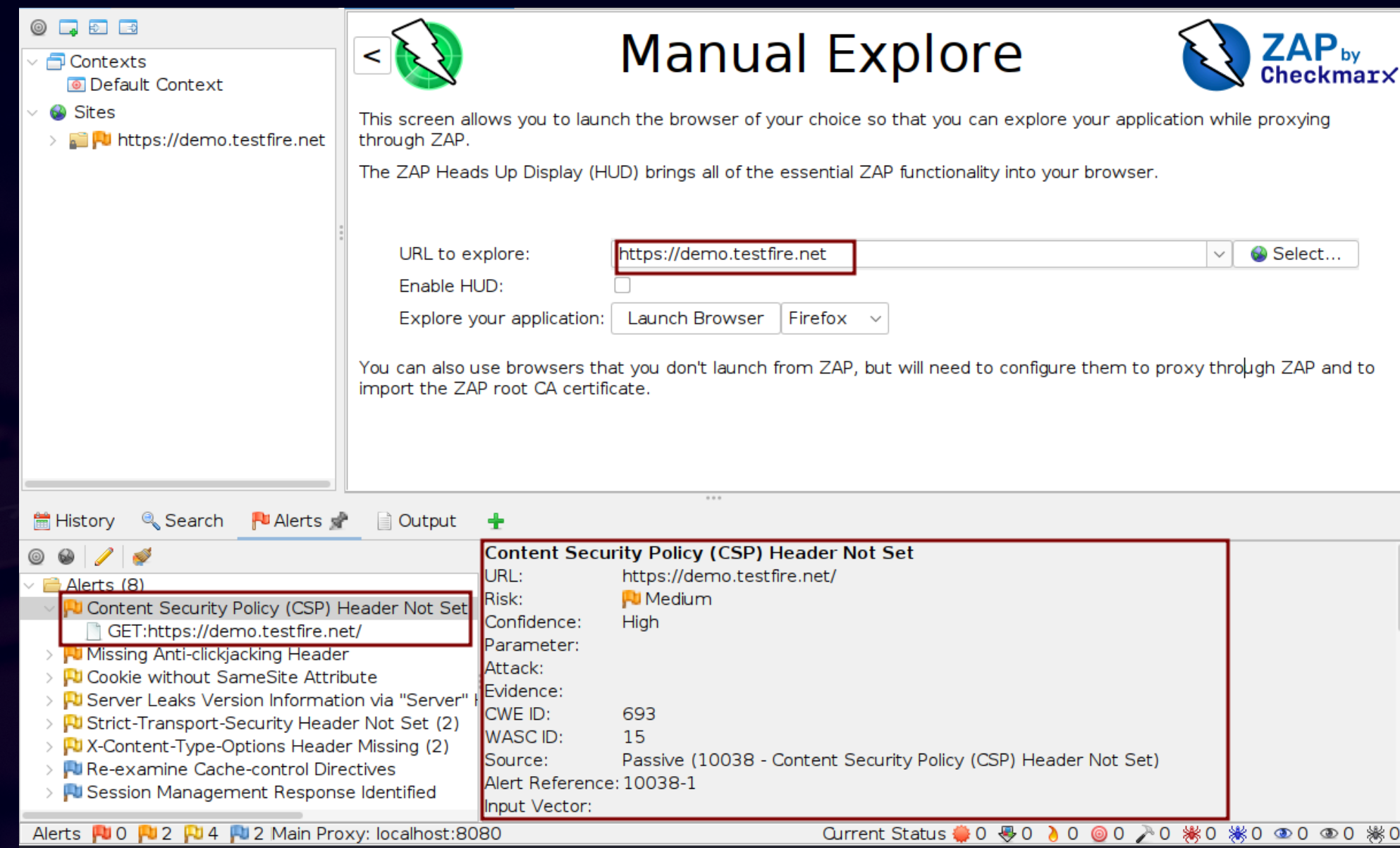
Exposed services

03

Missing security headers

FINDING 1

MISSING CONTENT SECURITY POLICY (CSP)



- Risk Level: Medium
- Issue: The website does not define a Content Security Policy header.
- Impact: This increases the risk of malicious scripts being executed in the browser
- Recommendation: Implement a CSP header to restrict trusted content sources.

Figure 1: OWASP ZAP – Missing Content Security Policy (CSP) Header

FINDING 2

MISSING ANTI-CLICKJACKING PROTECTION

- Risk Level: Medium
- Issue: The application does not include protection against clickjacking attacks.
- Impact: Attackers can trick users into clicking hidden elements.
- Recommendation: Add X-Frame-Options header with value DENY.

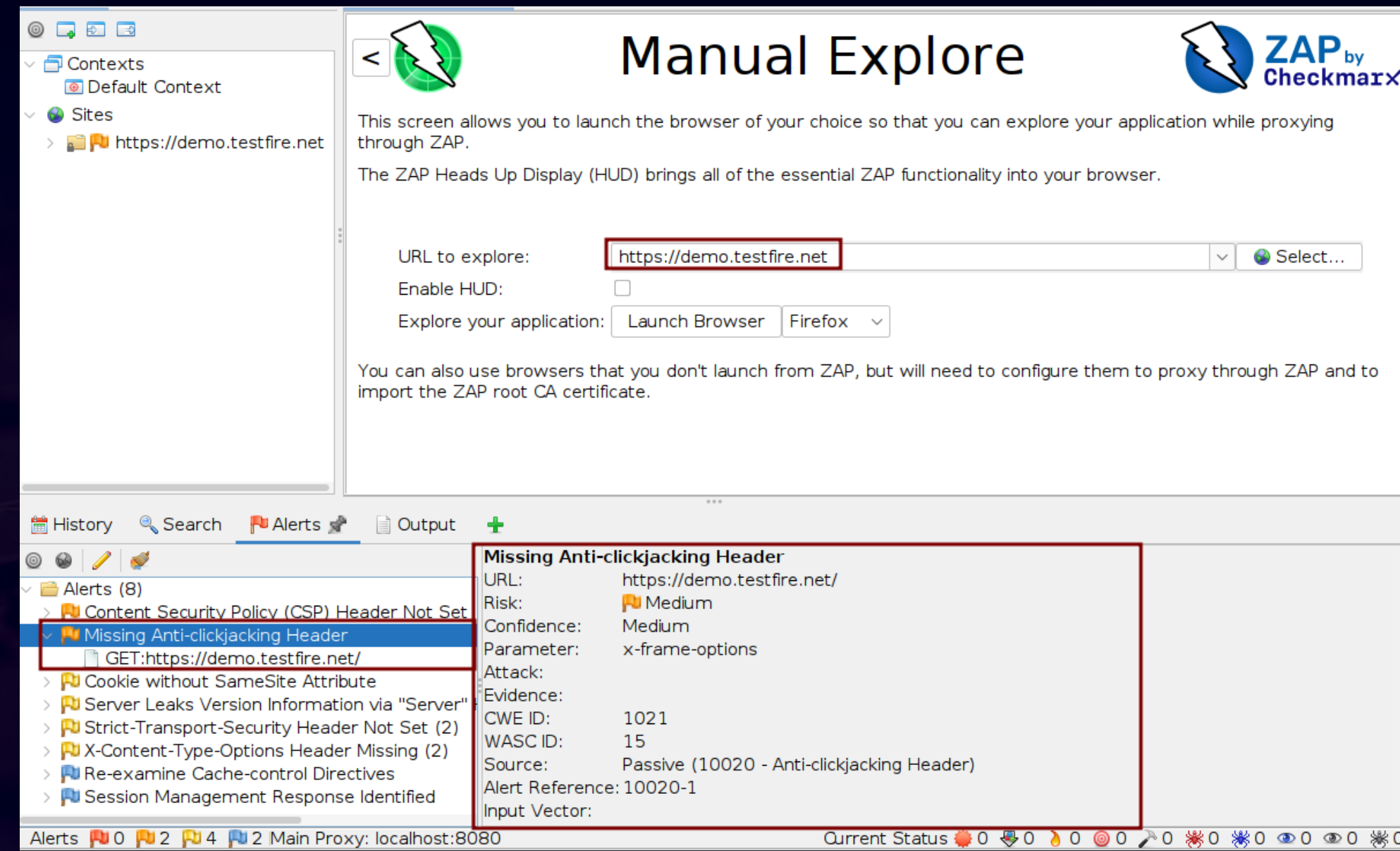
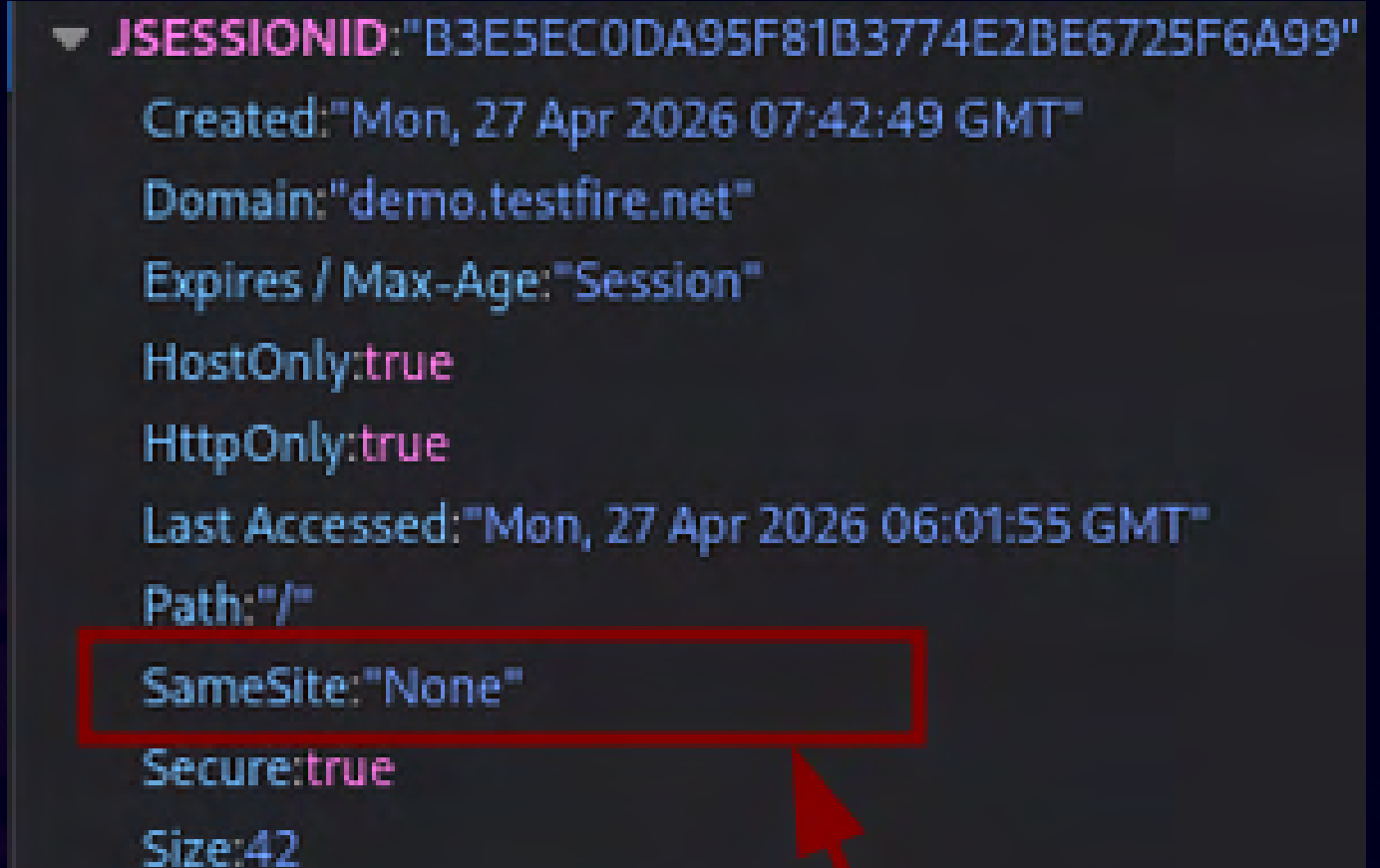


Figure 2: OWASP ZAP – Missing Anti-Clickjacking Header

FINDING 3

COOKIE WITHOUT PROPER SAME SITE RESTRICTION



```
▼ JSESSIONID:"B3E5EC0DA95F81B3774E2BE6725F6A99"  
  Created:"Mon, 27 Apr 2026 07:42:49 GMT"  
  Domain:"demo.testfire.net"  
  Expires / Max-Age:"Session"  
  HostOnly:true  
  HttpOnly:true  
  Last Accessed:"Mon, 27 Apr 2026 06:01:55 GMT"  
  Path:"/"  
  SameSite:"None"  
  Secure:true  
  Size:42
```

Figure 3: Browser DevTools – Session Cookie Attributes (JSESSIONID)

- Risk Level: Medium
- Issue: Session cookies are not properly restricted for cross-site usage.
- Impact: This may expose the application to CSRF attacks.
- Recommendation: Set SameSite=Strict for session cookies.

FINDING 4

SERVER INFORMATION DISCLOSURE

- Risk Level: Low
- Issue: The server reveals its software information (Apache-Coyote).
- Impact: Attackers may use this information to identify vulnerabilities.
- Recommendation: Disable server version disclosure.

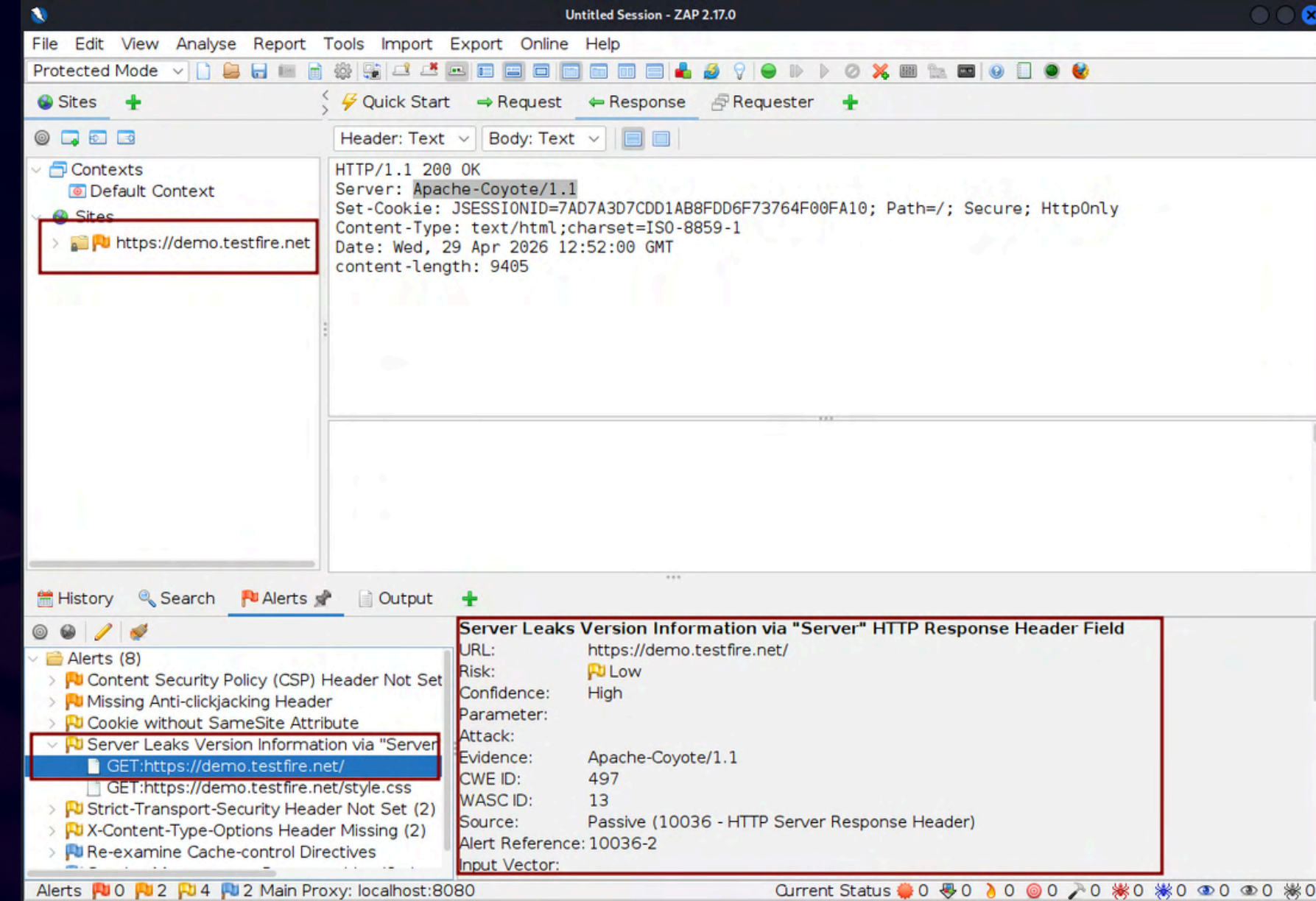


Figure 4: OWASP ZAP– Server Information Disclosure

FINDING 5

MISSING STRICT TRANSPORT SECURITY (HSTS)

- Risk Level: Medium
- Issue: The application does not enforce secure HTTPS connections.
- Impact: Users may be exposed to insecure communication
- Recommendation: Enable HSTS header to enforce HTTPS.

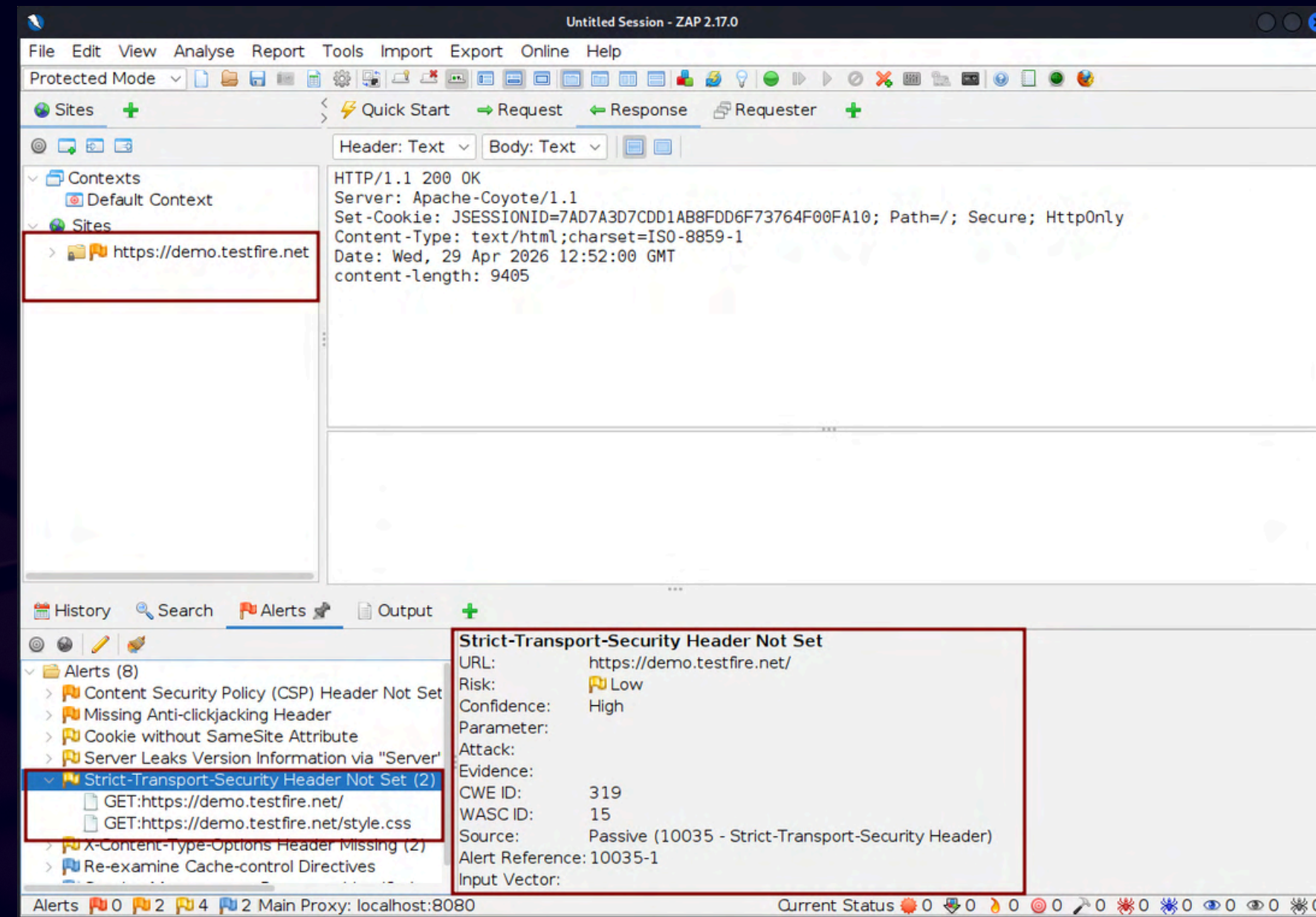


Figure 5: OWASP ZAP – Missing HSTS Header

FINDING 6

OPEN NETWORK PORTS

```
(kali㉿kali)-[~]  
└─$ nmap -F demo.testfire.net  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-29 16:13 EAT  
Nmap scan report for demo.testfire.net (65.61.137.117)  
Host is up (0.25s latency).  
Not shown: 95 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
443/tcp   open  https  
8080/tcp   open  http-proxy  
8443/tcp   closed https-alt  
  
Nmap done: 1 IP address (1 host up) scanned in 8.99 seconds
```

Figure 6: Nmap Scan – Open Ports and Services
Shows exposed services increasing attack surface.

- Risk Level: Medium
- Issue: Multiple ports (21, 80, 8080) are open and accessible.
- Impact: Open ports increase the attack surface of the system.
- Recommendation: Close unused ports and restrict access via firewall.

FINDING 7

MISSING SECURITY HEADERS

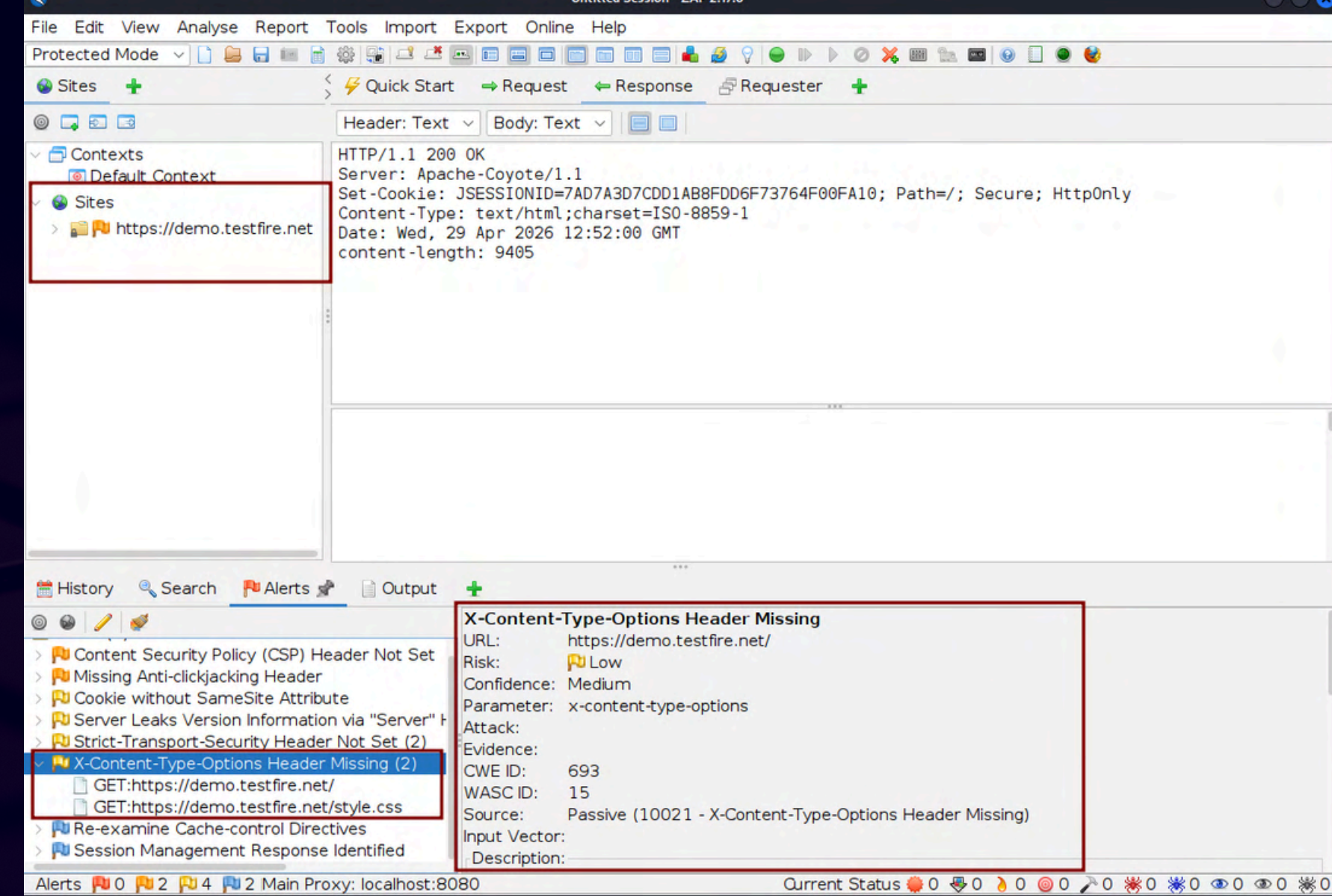


Figure 7: OWASP ZAP – Missing Security Headers

- Risk Level: Low-Medium
- Issue: Important headers like X-Content-Type-Options are missing.
- Impact: This may allow content-type attacks and other risks.
- Recommendation: Add X-Content-Type-Options: nosniff.

CONCLUSION OF FINDINGS

01

No critical vulnerabilities

02

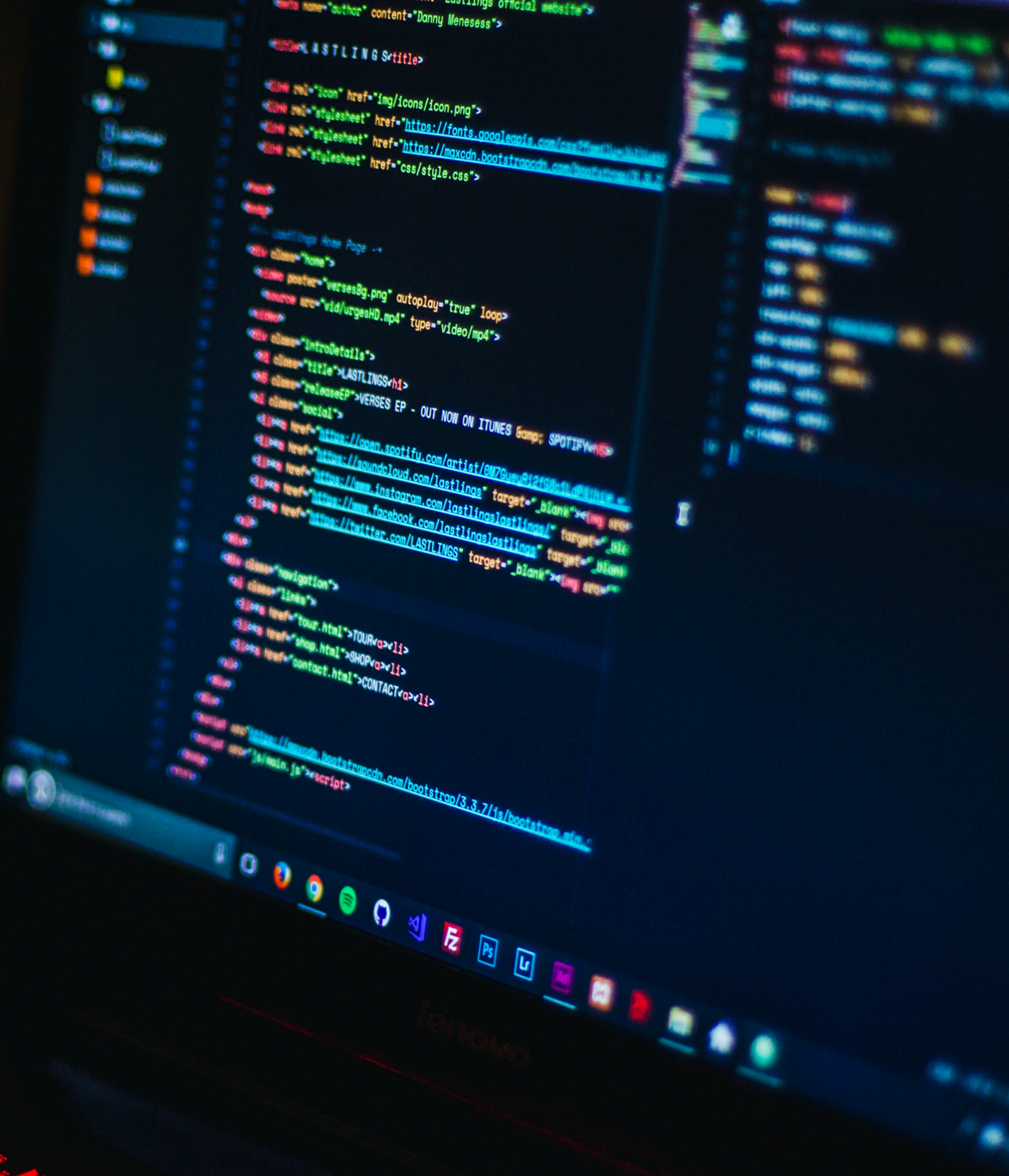
Several medium risks

03

Security can be improved

RISK SUMMARY

Risk Level	Count
Medium	4-5
Low	2-3





THANK YOU